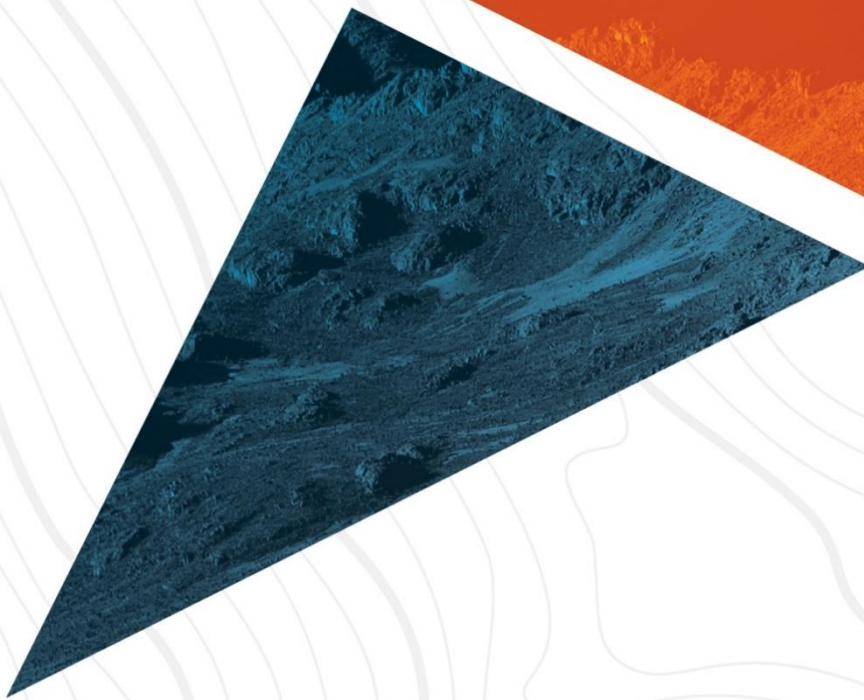




**Cyber Threat Intelligence (CTI) Report  
Information Stealers  
July 2025**

## Contents

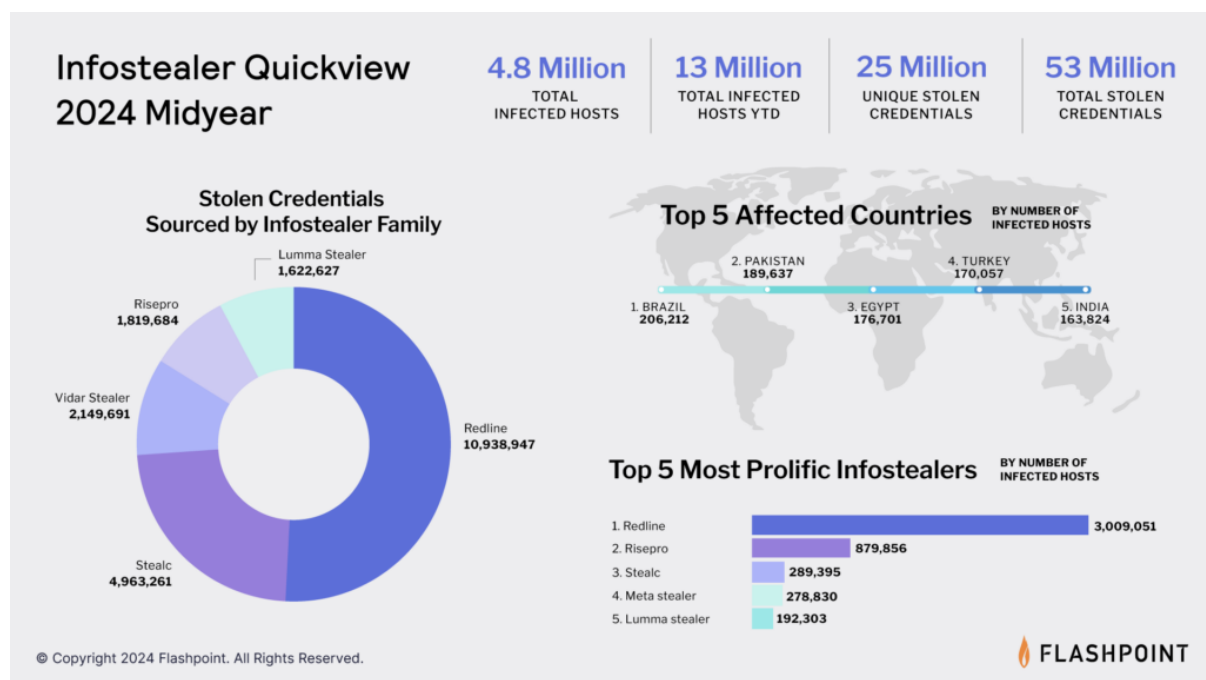
|                                          |           |
|------------------------------------------|-----------|
| Executive Summary .....                  | 3         |
| Introduction .....                       | 4         |
| Infostealer Evolution Timeline .....     | 4         |
| Threat Overview.....                     | 4         |
| Attribution .....                        | 5         |
| Case Studies .....                       | 6         |
| <b>1. Lumma stealer .....</b>            | <b>6</b>  |
| Command and Control .....                | 8         |
| Fake captcha.....                        | 9         |
| <b>2. Redline Infostealer .....</b>      | <b>12</b> |
| <b>3. Vidar Stealer .....</b>            | <b>16</b> |
| Tactics, Techniques and Procedures ..... | 16        |
| Indicators of Compromise (IoCs) .....    | 18        |
| Recommendations.....                     | 19        |
| Conclusion.....                          | 19        |
| References.....                          | 20        |

## Executive Summary

In recent months, the cybersecurity landscape has experienced a sharp rise in the use of information-stealing malware—commonly known as infostealers. While infostealers have existed for nearly two decades, their use surged dramatically between 2022 and 2025. Unlike ransomware that seeks immediate financial gain through extortion, infostealers silently harvest sensitive data such as credentials, session cookies, crypto wallets, and system information, often selling it on underground forums or using it in follow-up attacks like business email compromise and identity theft. This report outlines the evolution and activity of the most prominent infostealer families, their delivery methods, and the risks they pose to organizations, highlighting their increasing sophistication through techniques like leveraging legitimate remote access tools, bypassing antivirus solutions, and operating under malware-as-a-service (MaaS) models. As these threats continue to adapt, businesses must prioritize strong endpoint protection, user education, and integrated threat intelligence to defend against this evolving threat.

This report aims to:

- Provide an overview of **infostealer activity and trends** observed.
- Highlight **notable malware families** currently in circulation.
- Summarize **attack vectors, targeted data types, and post-infection risks**.
- Offer **actionable guidance** to improve resilience and visibility against these threats.



## Introduction

Infostealers are malicious programs designed to covertly harvest sensitive information, including login credentials, financial details, personal data, and cryptocurrency wallet information, often without detection. While the early wave of malware activity focused on destructive operations or high-profile ransomware attacks, today's threat actors are increasingly **leveraging infostealers for data-centric campaigns**. This shift reflects a broader trend: cybercriminals are prioritizing long-term monetization of stolen credentials, session data, and access tokens over immediate, noisy payoffs.

The use of **malware-as-a-service (MaaS)** platforms has further lowered the barrier to entry, allowing even less sophisticated actors to launch widespread infostealer campaigns. As a result, organizations of all sizes and sectors are at risk, particularly those with remote or hybrid workforces, distributed endpoints, and limited visibility into user behavior.

## Infostealer Evolution Timeline

- **Early 2000s:** The first infostealers started appearing in the wild. Notable early examples include **Zeus (2007)**, a banking trojan designed to steal login credentials.
- **2010s:** More advanced families like Pony, KeyBase, and LokiBot emerged, capable of extracting browser data, system info, and even crypto wallets.
- **2020–2021:** Infostealers such as RedLine, Raccoon, and Vidar gained popularity, fueled by the rise of **malware-as-a-service (MaaS)** offerings.
- **2022–2025:** Use exploded due to widespread distribution via phishing, malvertising, and fake software installers. A major crackdown by Microsoft and law enforcement took place in **May 2025**, targeting key families and infrastructure.

## Threat Overview

Infostealers have become a staple in the cybercriminal arsenal, driven by their **low cost, high return**, and the increasing value of stolen digital identities in underground markets. Unlike disruptive malware families like ransomware, infostealers focus on quietly collecting data that can be reused, resold, or exploited in future attacks.

Key Trends Shaping the Infostealer Ecosystem:

- **Growth of Malware-as-a-Service (MaaS):** Platforms like Lumma and Raccoon Stealer are distributed via MaaS models, allowing threat actors to subscribe to ready-made malware kits with ongoing support, infrastructure, and updates. This has democratized access to powerful infostealing tools.
- **Targeted Data Types:** Most infostealers focus on **browser-stored credentials, saved passwords, autofill data, cookies, crypto wallets**, system metadata, and occasionally screenshots or clipboard contents. **Session tokens** are increasingly being targeted to bypass MFA and hijack accounts.
- **Exfiltration Techniques:** Threat actors are shifting from traditional C2 channels to more obscure or legitimate-looking exfiltration methods, including Telegram bots, Discord

webhooks, and public cloud platforms (e.g., Dropbox, OneDrive). These help evade detection and bypass network security filters.

- **Blurred Lines with Other Malware Families:** Modern infostealers are often bundled with remote access trojans (RATs) or drop payloads that enable post-exploitation, privilege escalation, and even ransomware deployment. This makes them a gateway threat to more severe breaches.
- **Defense Evasion Tactics:** To avoid detection, infostealers are increasingly Packed or obfuscated, signed with stolen certificates, Using LOLBins (Living off the Land Binaries) and legitimate tools, and running in memory to bypass disk-based detection.

## Attribution

Information stealers are often attributed to financially motivated cybercriminal groups operating within underground forums or as part of malware-as-a-service (MAAS) ecosystems. Many infostealers like RedLine Stealer, Vidar, Raccoon stealer and Formbook have been linked to actors based in Eastern Europe, particularly Russia and neighboring regions. These malware authors may sell their tools or rent access via Telegram, dark web markets, or hacking forums.

Some campaigns also display signs of state-level sponsorship, particularly when info-stealers are used for espionage or credential harvesting in government, healthcare, or defense sectors.

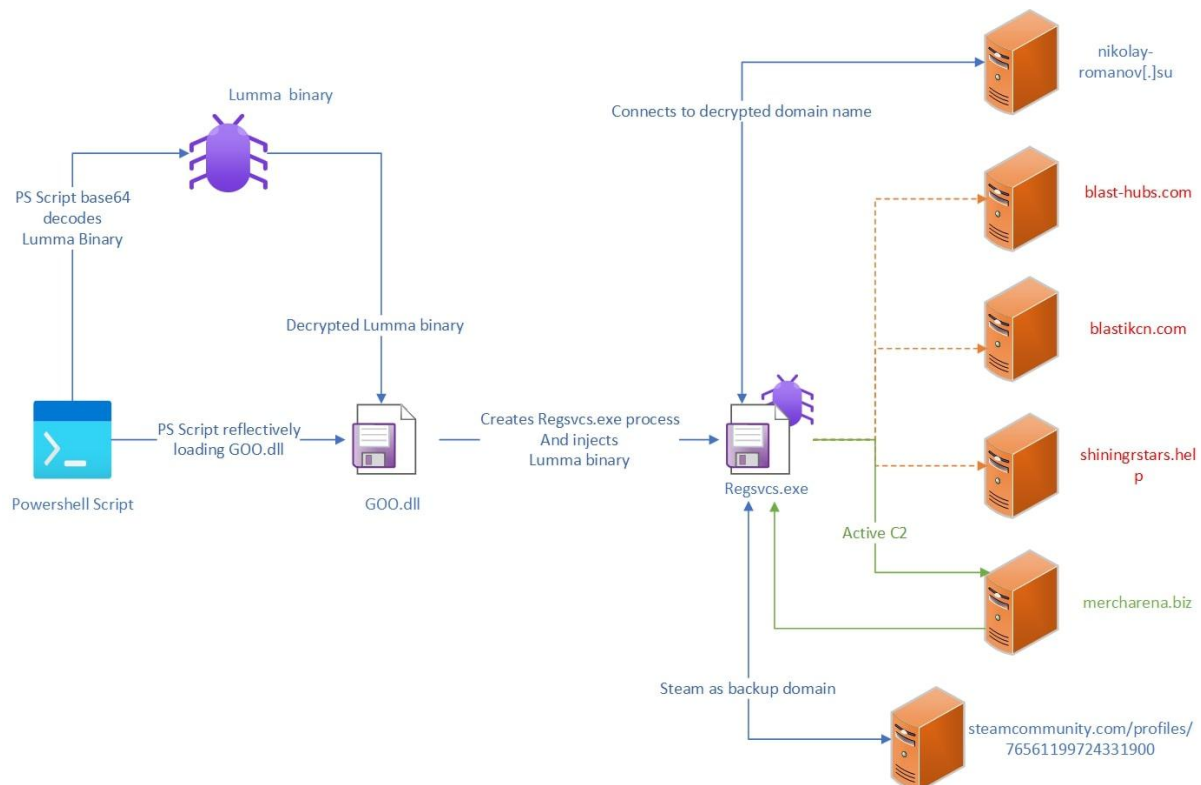
### **Notable Threat Actors and Malware Families**

| Malware Family  | Likely Attribution                                                 | Notes                                                                  |
|-----------------|--------------------------------------------------------------------|------------------------------------------------------------------------|
| Raccoon Stealer | Russian-speaking cybercriminals                                    | Sold as MAAS; developer arrested in 2022, but version 2 emerged later. |
| Redline Stealer | Eastern Europe actors                                              | Widely used in Phishing and Malvertising campaigns                     |
| LummaC2         | Russian Underground forums                                         | Known for rapid development and feature updates.                       |
| Vidar           | Linked to Arkei lineage which is linked to Russian speaking actors | Often bundled with cracked software.                                   |
| MetaStealer     | Chinese Speakers                                                   | Targets MacOS, rare among stealers.                                    |

## Case Studies

### 1. Lumma stealer

#### Infection chain



A flow chart showing how info stealers work (Lumma Stealer)

### Tactics, Techniques and Procedures

Infostealers leverage a broad and evolving set of delivery vectors. Campaigns often combine techniques, dynamically adapting to evade detection and increase infection success rates. Delivery infrastructure is designed to be ephemeral, shifting rapidly across domains, platforms and geographies to avoid takedowns.

- **Phishing emails:** Emails impersonate known brands and services to deliver links or attachments. These campaigns involve expertly crafted emails designed to evoke urgency, often masquerading as urgent hotel reservation confirmations or pending cancellations. Emails lead victims to cloned websites or malicious servers that deploy the Infostealer payload to the targets' environment.
- **Malvertising T1189:** Threat actors inject fake advertisements into search engine results, targeting software-related queries such as "Notepad++ download" or "Chrome update." Clicking these poisoned links leads users to cloned websites that closely mimic legitimate vendors but instead deliver the Info Stealer.



- **Drive-by download on compromised websites:** Threat actors were observed compromising groups of legitimate websites, typically through a particular vulnerability or misconfiguration. They modify site content by inserting malicious JavaScript. The JavaScript runs when sites are visited by unsuspecting users, leading to delivery of a payload, intermediary script, or displaying further lures to convince users to perform an action.
- **Trojanized applications T1204.002:** In many campaigns, cracked or pirated versions of legitimate applications are bundled with info stealers such as Lumma binaries and distributed through file-sharing platforms. These modified installers often contain no visible payload during installation, executing the malware silently post-launch.
- **Abuse of legitimate services and ClickFix:** Public repositories like GitHub are abused and populated with scripts and binaries, often disguised as tools or utilities. A particularly deceptive method involves fake CAPTCHA pages, commonly observed in the ClickFix ecosystem. Targets are instructed to copy malicious commands into their system's Run utility under the pretense of passing a verification check. These commands often download and execute Info stealer directly in memory, using Base64 encoding and stealthy delivery chains.
- **Initial Access TA0001:** Attackers have been impersonating trusted platforms like GitHub to deliver malicious links to victims. Urging users to download a "fix" – which was in fact Lumma Stealer. Adversaries abused Github's issue tracker and comment system to post fake "fixes" for open-source projects. Here is an example of a GitHub comment:

```
to fix your trouble check this fix, i see it in another issue,  
hxxps://app[.]mediafire[.]com/5mrkd33xulszl  
password: changeme  
when you installing, you need to place a check in install to  
path and select "gcc."
```

- **Scripting and loader execution T1059, T1218:** After initial binary is launched, Lumma Stealer's infection chain makes heavy use of script execution and system utilities to load the malware into memory.
- **Defense evasion and obfuscation T1027:** Lumma Stealer employs multiple obfuscation methods to evade detection.
  - a) **Base64 Encoding:** PowerShell scripts are often Base64-encoded to obscure their content.
  - b) **XOR Encryption:** used to encrypt strings and payloads, hindering static analysis.
  - c) **Junk code insertion:** inserts meaningless code to confuse analysis tools.
  - d) **Polyglot Files:** file with dual (e.g., mp3, .accdb, .pub) formats containing malicious JavaScript to bypass security scanners.
- **Living-off-the-Land-Binaries (T1218) and Process Injection (T1055):** Lumma stealer leverages trusted system binaries to execute malicious code.
  - a) **Mshta.exe** – executes remote HTA files containing malicious scripts.
  - b) **Wscript.exe** – runs malicious VBScript or JavaScript files.
  - c) **RegAsm.exe** – used for DLL injection into trusted processes, facilitating stealthy execution.

- d) **Process Hollowing (T1055.012)** – Injects malicious code into legitimate processes, replacing their memory to evade detection.
- **Cleanup and Anti-analysis (T1070.004, T1497.001)** – To avoid detection lumma stealer performs the following techniques:
  - a) **Deletes artifacts** – removes its working directory and temporary files post-execution using commands like:
  - b) **Virtualization/Sandbox Evasion** – Performs system checks to detect virtual environments or analysis tools, altering behavior accordingly.

Lumma stealer often cleans up its traces to avoid forensic detection.

Using a command like: `cmd.exe /c ... rd /s /q "<malware_folder>"` to silently remove the malware files and then exit. This corresponds to **Indicator Removal on Host – File Deletion (T1070.004)**, ensuring that no obvious malicious files remain on disk.

The malware also checks for the presence of security tools or virtualized environments (**T1497.001 – Virtualization/Sandbox Evasion: System Checks**)

- **Credential Access:** Lumma Stealer's primary goal is to collect and exfiltrate sensitive data- especially credentials and authentication tokens – from the infected system.
  - a) **Credentials from the web browsers (T1555.003) and Session Cookies (T1539):** Lumma stealer targets popular web browsers to obtain stored passwords, saved in login cookies, auto-fill data, browsing history, and other information that could grant access to online accounts. Upon execution, the stealer searches for browser data directories (for example, the chrome user profile folder) and accesses files such as login databases and cookies.
  - b) **Crypto currency wallets and other sensitive files (T1552.001):** lumma stealer scans for cryptocurrency wallet data and other financial information. It is configured to seek out wallet files or keys for various crypto applications, browser extensions and even authenticator browser extensions that store 2FA seeds. By grabbing these, the malware can compromise cryptocurrency accounts and bypass 2FA protections.
  - c) **Keylogging and Clipboard Dat (T1056.001 & T1115):** some variants of lumma stealer implement key logging, capturing keystrokes to pick up credentials that might not be stored in files.

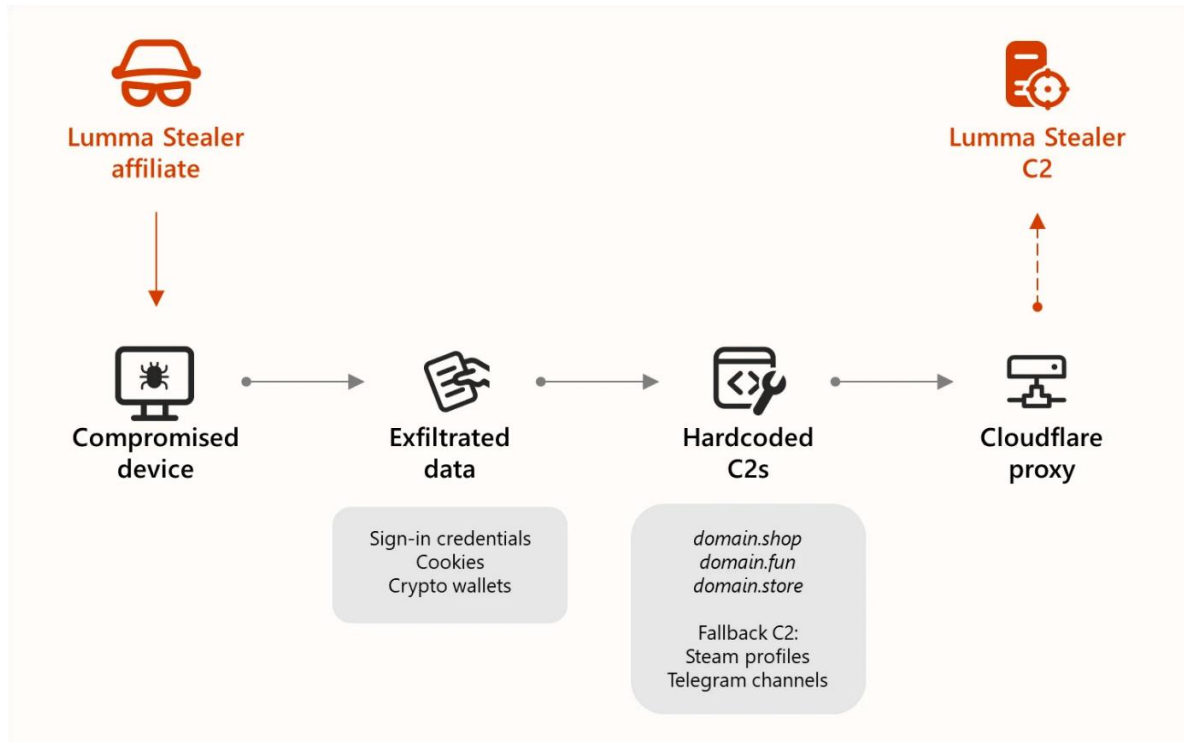
Lumma stealer binaries and scripts are heavily obfuscated to avoid antivirus detection and hinder reverse engineering. It even encrypts portions of its code to deter analysis and signature-based detection.

## **Command and Control**

All the stolen data – passwords, cookies, wallet keys, system info, etc.- is typically packaged into an archive or sent directly to the attacker's command-and-control (C2) server. Lumma stealer



communicates with its C2 over common web protocols (HTTP/HTTPS) and may encrypt or encode the data in transit for stealth.



*Lumma stealer C2 communication*

In early April 2025, Microsoft observed a cluster of compromised websites leveraging **EtherHiding** and **ClickFix** techniques to install Lumma Stealer.

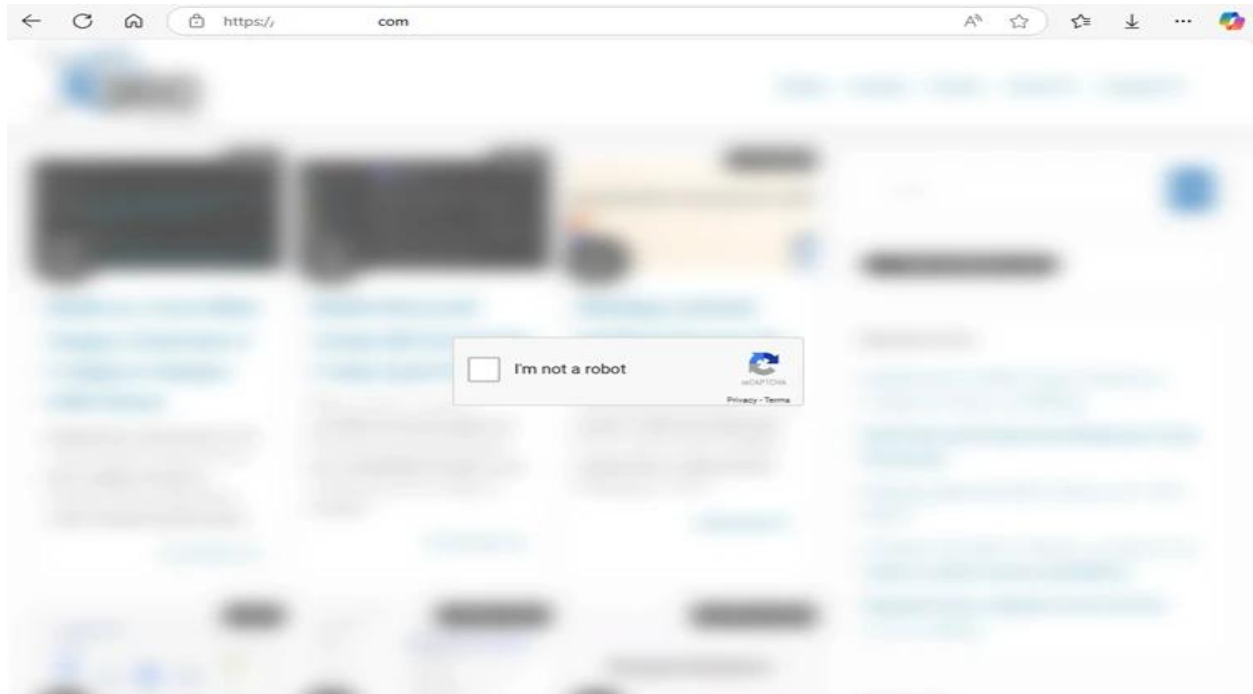
**EtherHiding** is a technique that involves leveraging smart contracts on blockchain platforms like Binance Smart Chain (BSC) to host parts of malicious code. Traditional methods of blocking malicious code, such as IP or domain blocking or content-based detections, are less effective against **EtherHiding** because the code is embedded in the blockchain.

Meanwhile, in the ClickFix technique, a threat actor attempts to take advantage of human problem-solving tendencies by displaying fake error messages or prompts that instruct target users to fix issues by copying, pasting, and launching commands that eventually result in the download of malware.

### **Fake captcha**

In this campaign, the JavaScript injected into compromised websites directly contacted BSC to retrieve the ClickFix code and lure, which was then presented to the target. Users needed to click the “I’m not a robot” prompt, at which point a command was copied into their clipboard.

Users were then instructed to paste and launch this command via the Windows Run prompt. The command downloaded and initiated further code using *mshta* from *check.foquh[.]icu*.



Compromised website used etherhiding and clickfix: Fake captcha page

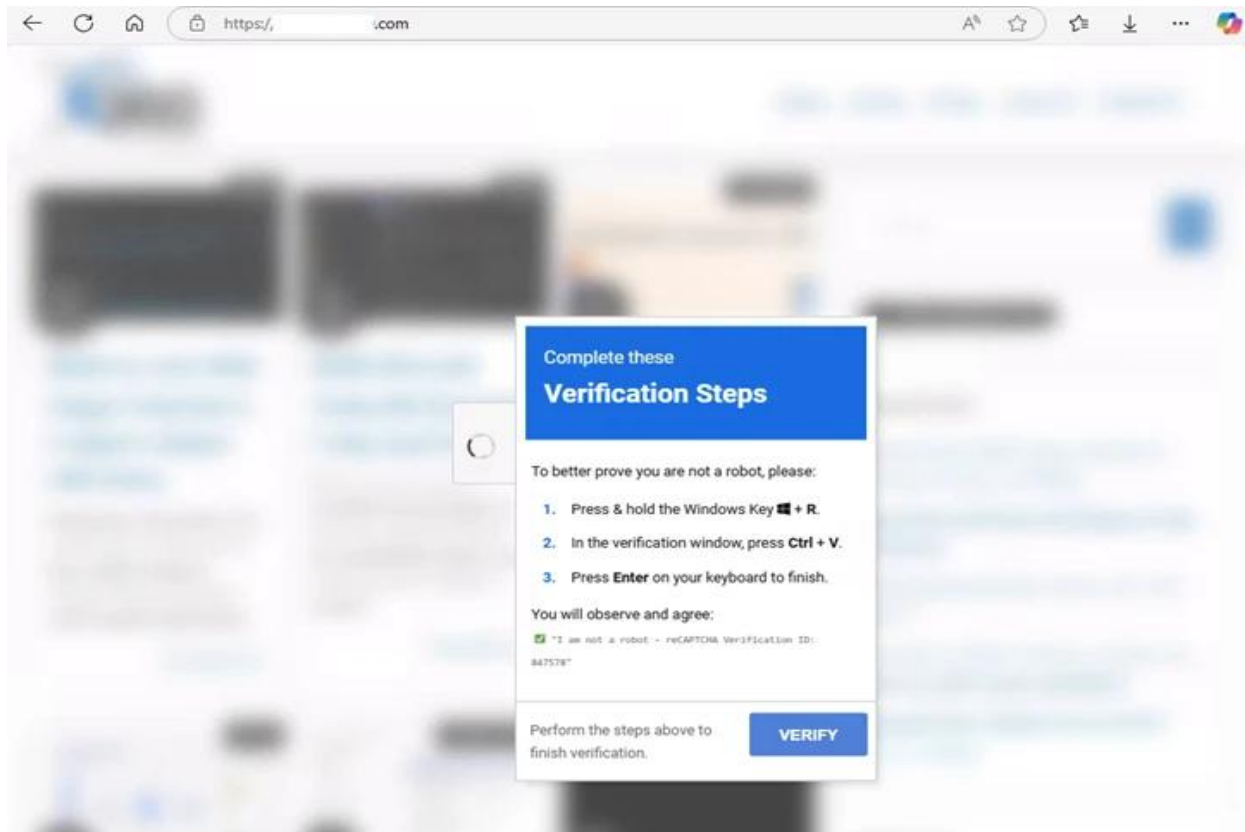
```

1  function _0x2c8f() {
2      const _0x237912 = [
3          'yLlRB',
4          '136734oyrs1Y',
5          'DHJkx',
6          'ebsc-1-s1.',
7          'WKeKL',
8          'toString',
9          '1058688ShOush',
10         'Lsqui',
11         'BIOYE',
12         'slice',
13         'length',
14         'bnbchain.o',
15         'userAgent',
16         '650659vMIXjy',
17         'HnMfL',
18         '1134hdInYy',
19         'rg:8545/',
20         'match',
21         '294Kcmqrm',
22         'oeSlD',
23         'https://ds',
24         'wrazw',

```

Snippet of the injected JavaScript after Base64 decoding. It implements the Etherhiding technique and communicates with data-seed-1-s1.bnbchain[.]org to fetch ClickFix code.

This verification page is the final part of the clickFix technique. It instructs the users how to launch a malicious command. The command was silently copied into their clipboard during the previous step where they clicked “I’m not a robot”.



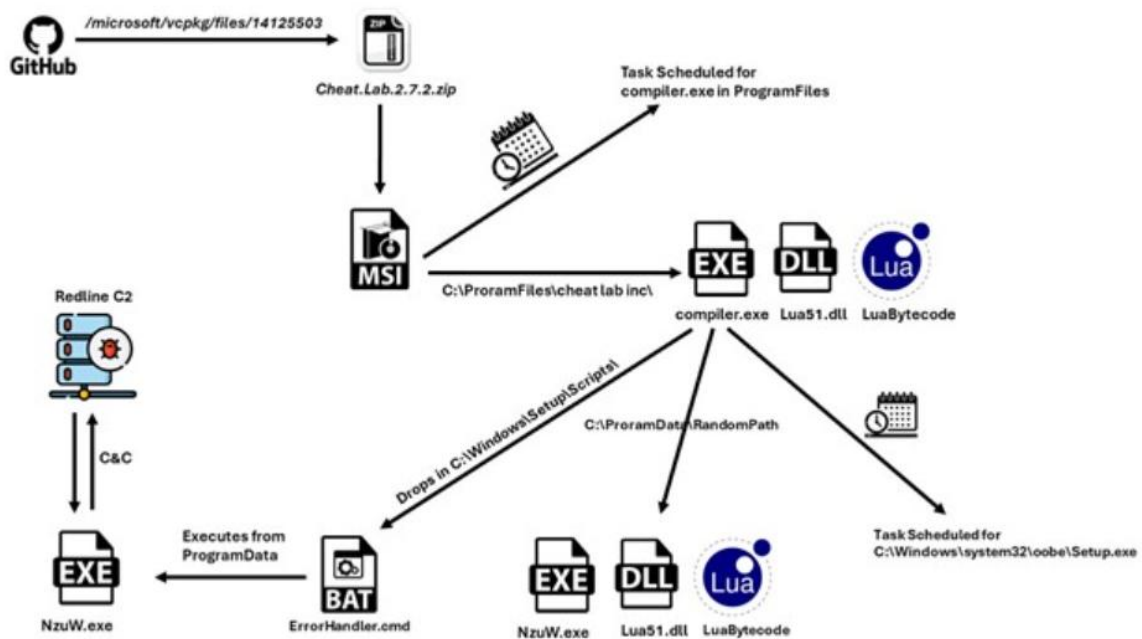
The threat actors turned the victim into the installer by social engineering them into running a command. This drive-by approach did not require a traditional phishing email; instead, it leveraged compromised web infrastructure and deceptive content.

By using web redirects and fake landing pages, the attackers achieved initial execution of malware code on victim machines without exploiting any software vulnerabilities, purely through social engineering and user interaction.

## 2. Redline Infostealer

A new packed variant of the Redline Stealer trojan was observed in the wild, leveraging Lua bytecode to perform malicious behavior.

### Infection Chain

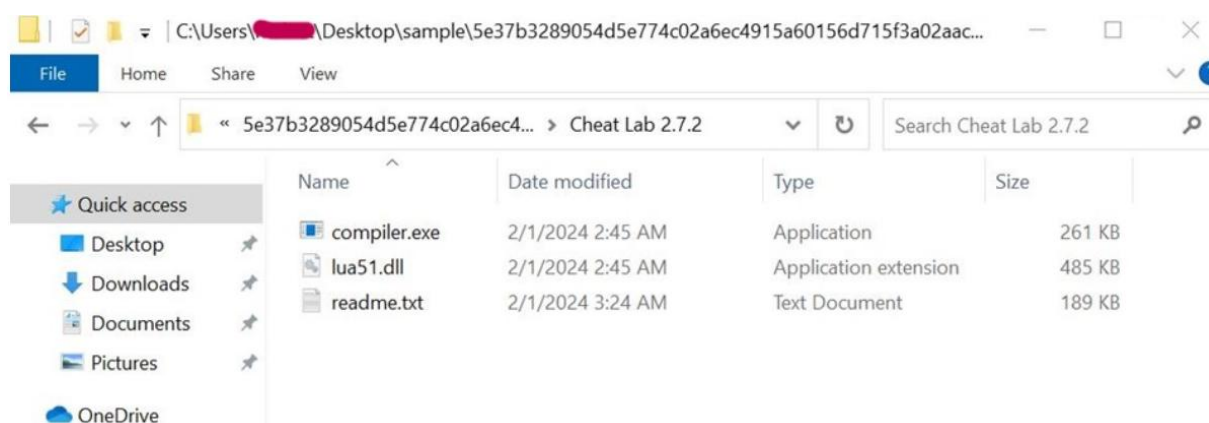


GitHub was being abused to host the malware file at Microsoft's official account in the vcpkg repository.

<https://github.com/microsoft/vcpkg/files/14125503/Cheat.Lab.2.7.2.zip>

hash: 5e37b3289054d5e774c02a6ec4915a60156d715f3a02aaceb7256cc3ebdc6610

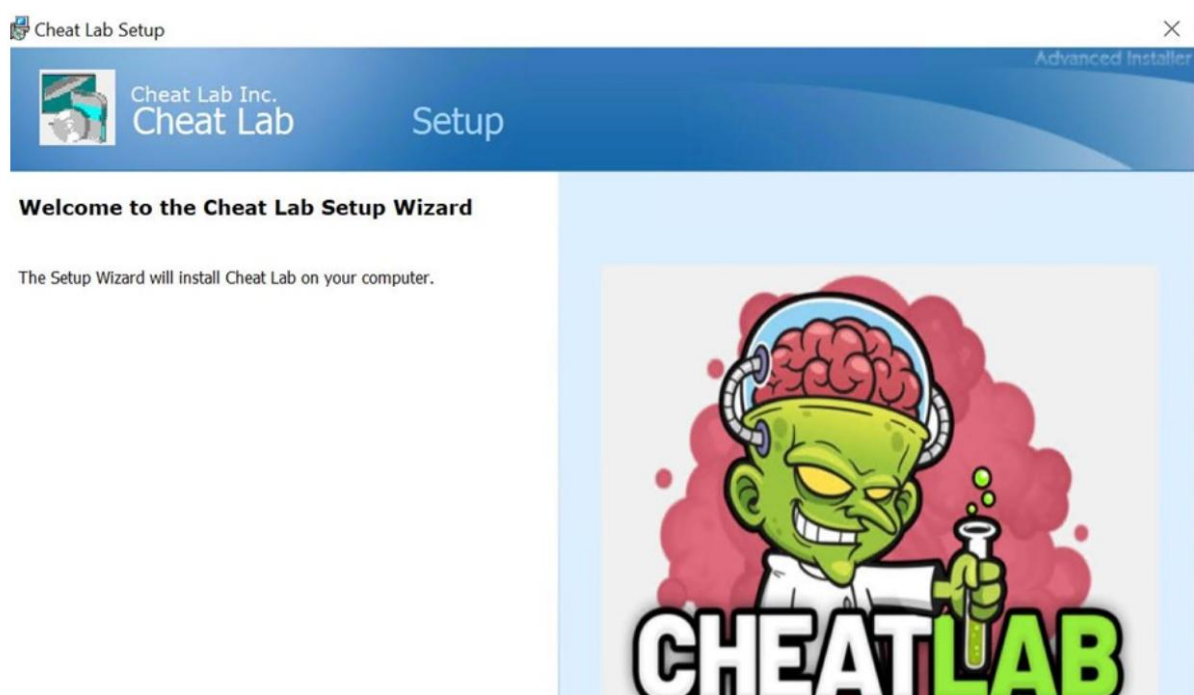
The zip file contains an MSI installer.



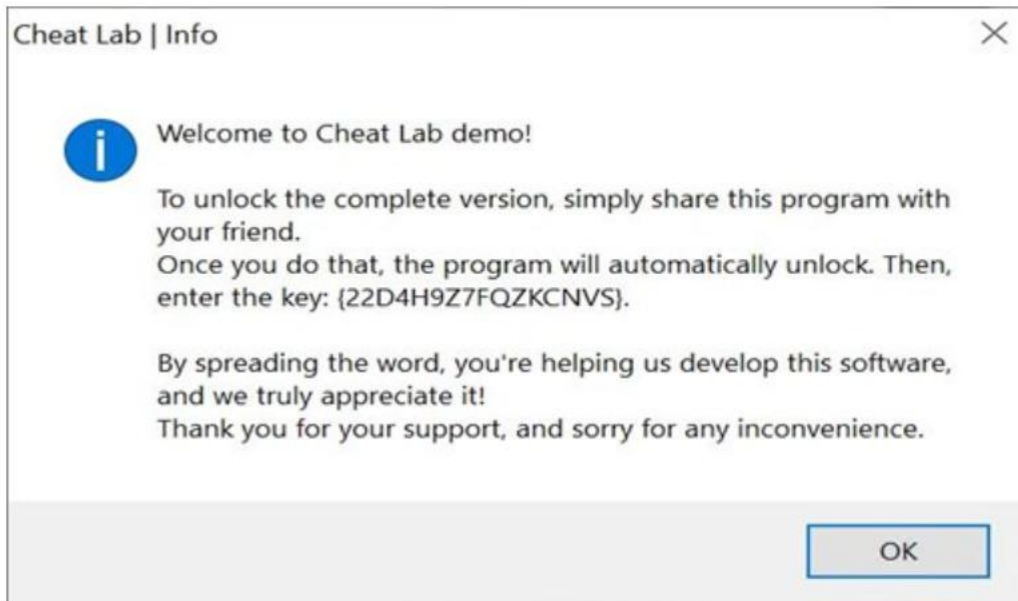
Compiler.exe and lua51.dll are binaries from the Lua project. However, they are modified slightly by a threat actor to serve their purpose; they are used here with readme.txt (Which contains the Lua bytecode) to compile and execute at Runtime.

Readme.txt, which contains the Lua bytecode. This approach provides the advantage of obfuscating malicious stings and avoiding the use of easily recognizable scripts like wscript, JScript, or PowerShell script, thereby enhancing stealth and evasion capabilities for the threat actor.

Upon execution, the MSI installer displays a user interface.



During installation, a text message is displayed urging the user to spread the malware by installing it onto a friend's computer to get the full application version.



During installation, three files are being written to Disk to C:\program Files\Cheat Lab Inc\ Cheat Lab\ path.

|         |              |      |                |                                                       |                                                                                                                                               |
|---------|--------------|------|----------------|-------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| 12:08.5 | msiexec.exe  | 5080 | Process Create | C:\Program Files\Cheat Lab Inc\Cheat Lab\compiler.exe | PID: 4588, Command line: "C:\Program Files\Cheat Lab Inc\Cheat Lab\compiler.exe" "C:\Program Files\Cheat Lab Inc\Cheat Lab\readme.txt"        |
| 12:08.5 | compiler.exe | 4588 | Process Start  |                                                       | Parent PID: 5080, Command line: "C:\Program Files\Cheat Lab Inc\Cheat Lab\compiler.exe" "C:\Program Files\Cheat Lab Inc\Cheat Lab\readme.txt" |
| 12:08.5 | compiler.exe | 4588 | Thread Create  |                                                       | Thread ID: 1628                                                                                                                               |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Program Files\Cheat Lab Inc\Cheat Lab\compiler.exe | Image Base: 0x7f700420000, Image Size: 0x46000                                                                                                |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Windows\System32\ntdll.dll                         | Image Base: 0x7f7ae3170000, Image Size: 0x1f5000                                                                                              |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Windows\System32\kernel32.dll                      | Image Base: 0x7f7ae3060000, Image Size: 0x8e000                                                                                               |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Windows\System32\kernelBase.dll                    | Image Base: 0x7f7ae09d0000, Image Size: 0x2c9000                                                                                              |
| 12:08.5 | msiexec.exe  | 5080 | Thread Exit    |                                                       | Thread ID: 2632, User Time: 0.0468750, Kernel Time: 0.0937500                                                                                 |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Windows\System32\apphelp.dll                       | Image Base: 0x7f7ade130000, Image Size: 0x90000                                                                                               |
| 12:08.5 | compiler.exe | 4588 | Thread Create  |                                                       | Thread ID: 2508                                                                                                                               |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Program Files\Cheat Lab Inc\Cheat Lab\lua51.dll    | Image Base: 0x7f7aa7660000, Image Size: 0x74000                                                                                               |
| 12:08.5 | compiler.exe | 4588 | Load Image     | C:\Windows\System32\ucrtbase.dll                      | Image Base: 0x7f7ae0e20000, Image Size: 0x100000                                                                                              |
| 12:08.5 | compiler.exe | 4588 | Thread Create  |                                                       | Thread ID: 4728                                                                                                                               |

Here, we see that compiler.exe is executed by msiexec.exe and takes readme.txt as an argument. Also, the Blue Highlighted part shows lua51.dll being loaded into compiler.exe. Lua51.dll is a supporting DLL for compiler.exe to function, so the threat actor has shipped the DLL along with the two files.

| Name         | Status | Triggers                                                                             | Next Run Time         |
|--------------|--------|--------------------------------------------------------------------------------------|-----------------------|
| CheatLabTask | Ready  | At 9:19 AM every day - After triggered, repeat every 1 hour for a duration of 1 day. | 2/18/2024 10:19:00 PM |

| General                                                                                                                                                                               | Triggers                                                                                                    | Actions | Conditions | Settings | History (disabled) |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|---------|------------|----------|--------------------|
| <p>When you create a task, you must specify the action that will occur when your task starts. To change these actions, open the task property pages using the Properties command.</p> |                                                                                                             |         |            |          |                    |
| Action                                                                                                                                                                                | Details                                                                                                     |         |            |          |                    |
| Start a program                                                                                                                                                                       | C:\Program Files\Cheat Lab Inc\Cheat Lab\compiler.exe "C:\Program Files\Cheat Lab Inc\Cheat Lab\readme.txt" |         |            |          |                    |



During installation, msixec.exe creates a scheduled task to execute compiler.exe with readme.txt as an argument.

- ✓ Apart from the above technique for persistence, this malware uses a 2nd fallback technique to ensure execution.
- ✓ It copies the three files to another folder in program data with a very long and random path.
- ✓ Note that the name compiler.exe has been changed to NzUW.exe.
- ✓ Then it drops a file ErrorHandler.cmd at C:\Windows\Setup\Scripts\
- ✓ The contents of cmd can be seen here. It executes compiler.exe under the new name of NzUw.exe with the Lua byte code as a parameter.

```
GET /json/?fields=query,status,statusCode,city,timezone HTTP/1.1
Content-Type: application/json; charset=utf-16
User-Agent: Winter
Host: ip-api.com
Cache-Control: no-cache

HTTP/1.1 200 OK
Date: Mon, 19 Feb 2024 07:44:17 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 108
Access-Control-Allow-Origin: *
X-Ttl: 60
X-Rl: 44

{"status": "success", "statusCode": "IN", "city": "Chennai", "timezone": "Asia/
Kolkata", "query": "115.118.240.109"}
```

We can see the network packet from api-api.com; this is written as a JSON object to Disk in the inetCache folder.

### **C2 Communication and stealer activity**

Communication with c2 occurs over HTTP.

The server sent the task ID of OTMsOTYs for the infected machine to perform. (in this case, taking screenshots)

A base64 encoded string is returned.

An HTTP PUT request was sent to the threat actors server with the URL /loader/screen.

After Dumping the bitmap image resource from Wireshark to disc and opening it as a .bmp(bitmap image) extension, we see.

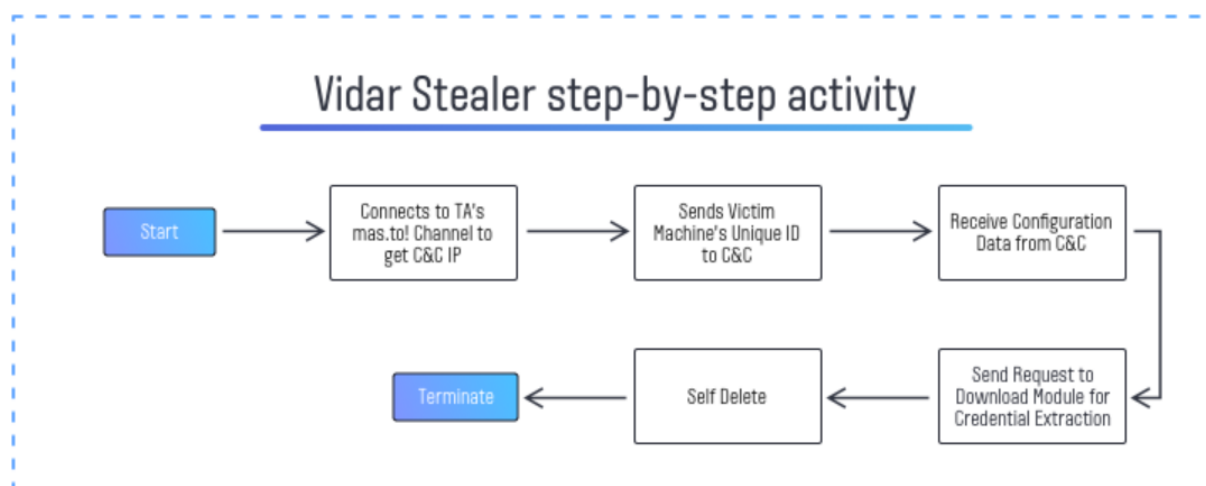
The screenshot was sent to the threat actors' server.

### **3. Vidar Stealer**

Vidar stealers, also known as Vidar spyware, are specialized malware that targets devices in an attempt to steal cryptocurrency wallet details and personal data. But Vidar is also occasionally used to infect machines with ransomware.

Vidar botnets have been around since 2018, although it's not always apparent where they came from. However, the authors acknowledged in an interview conducted in November 2023 that the virus is a development of the Arkei trojan. It functions as malware-as-a-service and is available for purchase straight from the dark web developer's website.

#### **Vidar Infection Chain**



#### **Tactics, Techniques and Procedures**

Social media is typically used by Vidar as part of its process and for its C2 infrastructure. The necessary C2 IP address is often included in the specifications of the Vidar malware, which frequently embeds the address to a particular social network profile. This gives the spyware complete access over the profile, enabling it to download files and instructions, communicate with the IP address, and even install other viruses.

However, the Vidar botnet's main purpose is to gather private data from an infected device and transmit it to the attacker because it is fundamentally an infostealer.

Vidar can steal a wide range of information, including: **Operating system data, Login credentials, Credit card or bank information, Browser history, Browser cookies, Software installed on the device, Downloaded files, Cryptocurrency wallets specifically, Exodus, Ethereum, MultiDoge, Atomic, JAXX, and ElectronCash**

### **Emails, FTP credentials**

When Vidar is used to install malware on a device, it may use its C2 infrastructure to specify a link from which to download and execute the infected file. This allows the attacker to gain access to the device, which they can then use or sell to other cybercriminals on the dark web.

Once downloaded onto a machine, it employs several techniques to avoid detection. Vidar stealers frequently utilize a big executable file to avoid being detected by antivirus scanners. Experts observed that Vidar samples contain null bytes at the end of the file (or zeroes at the end of an.exe file), artificially inflating the file size.

### **How Does Vidar Spread?**

Vidar virus is nearly always propagated via spam emails. In most cases, the victim receives a suspicious email that appears to be an invoice for an online purchase or a subscription renewal confirmation. The email will normally include an attachment that the target is instructed to view for more information. However, Vidar malware is included in the attachment, and when the target opens it, the malware is executed.

Typically, the attachment is a Microsoft Office document with a macros script. As a result, once opening the document, the user is prompted to enable macro execution. The device then connects to the malware server, allowing the Vidar stealer to be downloaded.

However, this meant that cybercriminals simply found different ways to spread the Vidar trojan. These include:

1. **Attachment ISO files:** Vidar malware can also be delivered as an attachment ISO file through email, such as an infected Microsoft Compiled HTML Help (CHM) file and executable "app.exe" file, which launches the malware when the attachment is opened
2. **.zip archives:** in one case, attackers impersonated fashion brand H&M to send phishing emails that directed recipients to a Google Drive folder, from which they would need to download a .zip archive to access a contract and payment information. The file would then launch the Vidar stealer attack from there.
3. **Fraudulent installers:** attackers can embed the Vidar spyware into a fraudulent installer for legitimate software that users may download such as Adobe Photoshop or Zoom and deliver it to targets as an attachment in a spam email
4. **Google Search ads:** more recently, one of the most common ways to circulate Vidar is through Google Search ads that have the malware embedded within their script. The attacker creates Google Ads that closely imitate those from a legitimate software publisher, and when unsuspecting users download this software and run it, the malware is executed and infects their device.

Ransomware associations: in some cases, the Vidar botnet has executed attacks in conjunction with various ransomware, such as STOP/Djvu and GandCrab, or malware like PrivateLoader and Smoke. In these highly malicious attacks, the two malwares have been spread together, leading to more extensive infections, data stealing — and problems for the user whose device is infected.

## Indicators of Compromise (IoCs)

Indicators of Compromise in information stealers are traces like file hashes, Command-and-control servers(C2) IPs, registry keys modifications, and network patterns help detect and respond to infections. They are crucial for identifying affected systems and blocking data exfiltration.

### **File Hashes (SHA-256)**

| Malware         | SHA-256                                                          | Description                                                                                                |
|-----------------|------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| RedLine Stealer | 355c9f31d4f4cf6242a8bedf18d47dbcf2cf863abbe83acd6c8beb9e89e3aad2 | Packed .NET binary. Steals browser data.                                                                   |
| Vidar Stealer   | 09267e88154b76a263fd7501e1325744a316ac686182c175deof383a6616d6f2 | Auto-exfiltrates via Telegram webhook. Often bundled with cracked software                                 |
| LummaC2         | 2e59bd7db699a8a7063c44ad2da160316941bef24b18654eae8de5fc97cabb57 | Stealer with modular C2. Distributed via fake CAPTCHA pages                                                |
| Agent Tesla     | 623d707cab5c5dc378a5100018e29f88949f4ea4be4b34cc2fc36e1612b68100 | Keylogger and stealer. It uses SMTP/FTP/Telegram for exfiltration. Delivered via macro-enabled Excel files |
| Raccoon Stealer | f89a1fc11a995b035aca4d23f8a391079e5d8f889b5a99866do7fdc755a65d77 | MaaS stealer. Targets browsers, wallets, and FTP clients                                                   |

### **Command & Control (C2) Domains and IPs**

| IP Address           | Domain                    | Stealer/Type    | Notes                          |
|----------------------|---------------------------|-----------------|--------------------------------|
| 185[.]141[.]63[.]120 | api.lumma[.]cc/api/upload | LummaC2         | SSL used; encrypted data blobs |
| 185[.]215[.]113[.]20 | synccloud[.]cc            | RedLine         | Drops stealer payload          |
| 45[.]153[.]241[.]10  | raccoonlog[.]ru           | Raccoon Stealer | Suspicious DNS tunneling       |
| 62[.]204[.]41[.]54   | metastealerbot[.]xyz      | MetaStealer     | Used Telegram bot C2 fallback  |

## Recommendations

- **Security awareness training:** this is an important step in helping employees identify and arousing their suspicion concerning unsolicited emails and phishing campaigns, especially messages with embedded links or attachments.
- **Restrict use of unapproved tools:** discourage downloading apps or softwares from unofficial sources. Use only approved platforms and applications for work.
- **Promote strong password habits:** remind employees of the risks associated with credential reuse and weak passwords. Support this with effective password policies, to encourage best practices.
- **Use MFA (Multi Factor Authentication):** MFA provides an extra layer of security that prevents unauthorized access to accounts, tools, systems and data repositories.
- **Avoid pirated software:** Educate users to only use legitimate software or applications.
- **Support regular software updates:** ensure that company devices and software are kept up to date.
- **Continuous monitoring:** monitoring unusual endpoint behavior, such as excessive requests to specific webhosts using unusual user-agent strings, to serve as an early indicator of compromise.

## Conclusion

Stealers such as redline, raccoon, Lumma and Vidar are renowned in the Maas market for their stealing capabilities and are expected to preserve their popularity. Especially Lumma and Redline, due to their ease of use, constant updates, and effectiveness.

Info Stealers continue to pose a significant threat to data security. It constantly adapts its TTPs and payloads to bypass security defenses. Adili Cyber remains committed to persevering in the fight against this ever-evolving malware, ensuring the protection of our customers' data.

## References

<https://securelist.com/lumma-fake-captcha-attacks-analysis/116274/>

<https://www.group-ib.com/blog/fakesecurity-raccoon/>

<https://www.recordedfuture.com/blog/shining-light-on-redline-stealer-malware>

[https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/?utm\\_source=chatgpt.com](https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/?utm_source=chatgpt.com)

<https://www.mcafee.com/blogs/other-blogs/mcafee-labs/redline-stealer-a-novel-approach/>

[https://www.kaspersky.com/resource-center/threats/vidar-stealer?utm\\_source=chatgpt.com](https://www.kaspersky.com/resource-center/threats/vidar-stealer?utm_source=chatgpt.com)

[https://www.picussecurity.com/resource/blog/lumma-infostealer-continues-its-github-social-engineering-campaign?utm\\_source=chatgpt.com](https://www.picussecurity.com/resource/blog/lumma-infostealer-continues-its-github-social-engineering-campaign?utm_source=chatgpt.com)

[https://cyberint.com/blog/research/meet-azorult-stealer-high-risk-open-source-evolving/?utm\\_source=chatgpt.com](https://cyberint.com/blog/research/meet-azorult-stealer-high-risk-open-source-evolving/?utm_source=chatgpt.com)

<https://www.darktrace.com/blog/the-rise-of-the-lumma-info-stealer>